

Warden: A Deterministic Pre-Action Governance Gate for Autonomous AI Agents

Jai Keshav Sharma*, Saurabh Kumar*

*Department of Computer Science & Engineering
Chhattisgarh Swami Vivekanand Technical University, Bhilai, India
{jaikeshav, saurabh}@csvtu.ac.in

Dr. Nachiket Tapas†

†Associate Professor, Department of CSE
Chhattisgarh Swami Vivekanand Technical University, Bhilai, India
nachiket.tapas@csvtu.ac.in

Abstract—Autonomous AI agents are being deployed in enterprise environments to execute multi-step workflows over sensitive backend APIs — yet the governance infrastructure required to operate them safely does not exist. The best frontier models complete only 30.3% of realistic enterprise tasks without human intervention (CMU TheAgentCompany, NeurIPS 2025), and per-step error compounding drives trajectory success below 2% at action depth 50. Existing identity and access management (IAM) infrastructure addresses *authentication* — confirming who an agent is — but provides no mechanism for *pre-action authorisation*: determining whether a specific tool call, with specific parameters, is permitted under the live policy governing that session. A converging regulatory and standards stack — OWASP ASI Top 10 (Dec. 2025), NIST CAISI Agent Standards Initiative (Feb. 2026), CSA Agent Identity Governance Framework (Mar. 2026), IETF WIMSE credentials (Jul. 2026), MCP Authorization Specification (Jul. 2026), and EU AI Act Article 50 (Aug. 2026) — defines what must be enforced, but no production-ready Policy Decision Point (PDP) exists. We survey this landscape, formalise the pre-action authorisation problem, and propose Warden: a deterministic governance gate that intercepts agent tool calls, evaluates them against compiled policy rules in under 40 ms (P95), and records every decision in a Merkle hash-chained, tamper-evident audit ledger.

Index Terms—AI agent governance, pre-action authorisation, policy decision point, OWASP ASI, EU AI Act, IETF WIMSE, MCP, audit ledger, enterprise security

I. INTRODUCTION

The enterprise deployment of autonomous AI agents is growing at an unprecedented rate. IBM’s 2026 executive study [13] projects a **38% year-on-year increase** in agent deployments by 2027; Gartner forecasts that 40% of enterprise applications will incorporate task-specific agents by end of 2026, up from fewer than 5% in 2025. Yet agent reliability remains deeply problematic. In the most realistic enterprise benchmark published to date, the best-performing model achieved only **30.3%** full task completion on multi-step workplace workflows [1].

The reliability shortfall compounds with action depth. For an agent with per-step failure probability $\bar{p}_f$, trajectory success

at depth d decays exponentially:

$$S(d) = S_0 \cdot \prod_{k=1}^d (1 - p_f(k)) \approx S_0 \cdot (1 - \bar{p}_f)^d \quad (1)$$

At empirically measured $\bar{p}_f \approx 0.10$, a 25-step enterprise workflow fails with probability exceeding 90%; at depth 50, the success rate collapses below 1.5%. Without a pre-action gate, every failed step carries the risk of an irreversible consequence — a deleted record, an unauthorised financial transaction, or a privilege escalation.

A. The Authentication–Authorisation Gap

The industry has invested heavily in *agent authentication*: platforms such as Okta for AI Agents, Arcade.dev, and Scalekit issue agent identities, manage OAuth delegation, and broker credential lifecycles. The IETF WIMSE working group [9] and MCP Authorization Specification [10] standardise credential formats. Authentication is approaching solved.

What does not exist is *pre-action authorisation*: a deterministic mechanism that answers, at tool-call time, whether a specific action with specific parameters is permitted under the live policy governing that session. Existing IAM operates at connection or session granularity. It cannot enforce that a payment agent may issue refunds only up to \$200, only during business hours, only to accounts not flagged in the past 24 hours, and only under a policy version that has not been revoked. Research confirms the severity: without a pre-action gate, adversarial injection succeeds in **74.6%** of attempts [2]. With a restrictive deterministic gate, the same suite achieves **0.0%** success across 879 attempts.

B. A Converging Standards Landscape

Six major governance artefacts were published or entered force in the twelve months before this writing: OWASP ASI Top 10 (Dec. 2025) [4], NIST CAISI Agent Standards Initiative (Feb. 2026) [6], CSA Agent Identity Governance Framework (Mar. 2026) [7], IETF WIMSE workload credentials draft-02 (Jul. 2026) [9], MCP Authorization Specification (Jul. 2026) [10], and EU AI Act Article 50 transparency

TABLE I
THEAGENTCOMPANY BENCHMARK RESULTS (NEURIPS 2025). BEST
AGENT VIA OPENHANDS CODEACT FRAMEWORK.

Model	Full Completion	Partial Score
Gemini 2.5 Pro	30.3%	39.3%
Claude 3.7 Sonnet	26.3%	36.4%
Claude 3.5 Sonnet	24.0%	34.4%
GPT-4o	8.6%	16.7%
Llama 3.1-405B	7.4%	—
Qwen 2-72B	1.1%	4.2%

obligations (Aug. 2026) [11]. These standards define what must be enforced. None provides an enforcement engine.

C. Contributions

This paper makes three contributions:

- 1) A structured survey of academic research, security standards (OWASP, NIST, CSA, IETF), and regulatory requirements pertaining to pre-action authorisation for AI agents (§II).
- 2) A formal gap analysis showing that no existing system provides a production-ready pre-action PDP (§III).
- 3) The **Warden** system proposal: a four-module governance gate with a natural-language policy compiler, a sub-40 ms runtime enforcement engine, a policy-currency invalidation mechanism, and a Merkle hash-chained tamper-evident audit ledger (§IV).

II. BACKGROUND AND RELATED WORK

A. Empirical Agent Reliability

TheAgentCompany [1] is the most ecologically valid enterprise benchmark to date. Xu et al. constructed a self-contained simulated software company with internal GitLab, RocketChat, and web portals, comprising 175 multi-step tasks requiring browsing, coding, program execution, and coordination with simulated coworkers (3,000+ construction person-hours). Table I lists scores for prominent models. The dominant failure modes are complex UI navigation, long-horizon planning with ambiguous goals, and parameter errors on high-privilege API calls.

Beyond task scores, Equation (1) reveals a more severe structural problem: at $\bar{p}_f = 0.10$, failure rates for depths $d \in \{10, 25, 50\}$ are approximately 65%, 92%, and 99.5%, respectively. A meta-survey of agent benchmarks [12] confirms that no existing benchmark evaluates governance-relevant failure modes such as privilege escalation or stale-policy exploitation.

B. Academic Pre-Action Authorisation Systems

Open Agent Passport (OAP). The OAP group [2] provide the first formal characterisation of the pre-action authorisation problem: the gap between probabilistic model alignment (Layer 1) and retrospective post-hoc evaluation (Layer 4). OAP intercepts tool calls synchronously before execution, evaluates them against declarative policy, and produces cryptographically signed audit records. On 4,437 authorisation decisions across 1,151 sessions: median enforcement latency **53 ms**;

adversarial success rate under permissive policy **74.6%**; adversarial success rate under restrictive OAP policy **0.0%** (879 attempts). OAP does not include a natural-language policy compiler or a tamper-evident audit ledger — both are Warden novelties.

Policy Constraint Layer (PCL). PCL [3] is a zero-ML deterministic authorisation engine evaluating five constraint classes: identity binding, channel trust, approval constraints, target/scope validation, and coupled policy. On PCL-Bench v1 (107 scenarios, 19 attack classes): F1 = 1.0000, false positive rate = 0%, mean latency **7.09 μ s**. PCL demonstrates that pre-action gates need not carry significant latency overhead; however, it lacks NL policy compilation, policy-currency invalidation, and MCP integration.

Microsoft Agent Control Specification (ACS). ACS is a stateless, deterministic runtime for policy evaluation at four intervention points: pre-model call, pre-tool call, post-tool call, and pre-response. It is part of Microsoft’s Agent Governance Toolkit (preview).

C. OWASP Agentic Security Initiative (ASI Top 10)

Released December 9, 2025 at Black Hat Europe by 100+ experts with review from NIST, the European Commission, and the Alan Turing Institute [4], the ASI Top 10 defines the canonical vulnerability taxonomy for agentic systems. It complements — not replaces — the LLM Top 10 (model I/O boundary) and MCP Top 10 (transport layer). Table II maps each vulnerability to its pre-action control.

D. NIST AI Risk Management Framework

NIST AI RMF 1.0 (Jan. 2023) [5] organises AI risk management across four functions — GOVERN, MAP, MEASURE, MANAGE — with 19 categories and 72 subcategories. NIST AI 600-1 (Jul. 2024) maps these to 12 generative AI risk categories; *Information Security* is the category most directly addressed by a pre-action gate.

NIST itself acknowledges that RMF 1.0 was designed for “primarily discriminative classifiers or conversational assistants.” Its Center for AI Standards and Innovation (CAISI) launched an AI Agent Standards Initiative in February 2026 [6], with the first AI Agent Interoperability Profile expected Q4 2026. The CSA Agentic NIST AI RMF Profile v1 (Feb. 2026) [8] bridges this gap, proposing autonomy tiering, per-tool risk scoring, and delegation accountability extensions.

E. Cloud Security Alliance Agentic Frameworks

Agent Identity Governance Framework (AIGF). CSA AIGF v1 (Mar. 2026) [7] categorises AI agent identities into five types (Orchestrator, Task, Tool, Human-Delegated, System) and introduces a just-in-time (JIT) access model: intent-declared, time-bound, scope-limited grants replacing standing agent privileges.

Agentic AI Governance Maturity Model (AGMM). A CSA/Google Cloud study finds that 84% of organisations cannot pass a compliance audit focused on agent behaviour; only 26% have comprehensive AI security governance; $\approx 70\%$

TABLE II
OWASP ASI TOP 10 (2026): VULNERABILITY CATALOG AND PRE-ACTION CONTROLS.

ID	Name	Threat Mechanism	Pre-Action Control
ASI01	Agent Goal Hijack	Prompt overrides in external data redirect agent objectives	Deterministic out-of-band AST evaluation; ignores conversational context
ASI02	Tool Misuse	Agent misuses legitimate tools beyond delegated scope	Session-scoped parameter thresholds; tool allowlists
ASI03	Privilege Abuse	Sub-agents inherit parent OAuth scope; cached creds exploited	SPIFFE/WIMSE attestation; monotonic capability decay
ASI04	Supply Chain Attack	Tampered MCP server injects malicious tool definitions	Tool provenance verification; signed MCP registry
ASI05	Unexpected RCE	Agent executes attacker-controlled code	Deny-by-default egress; pre-action code pattern block
ASI06	Memory Poisoning	Corrupted vector store induces future unauthorised actions	Policy-currency re-verification on memory writes
ASI07	Insecure Inter-Agent	Spoofed or replayed messages between agents	WIMSE Workload Proof Token; signed envelopes
ASI08	Cascading Failures	Transitive privilege accumulation across agent graph	RFC 8693 scope attenuation; circuit breaker
ASI09	Trust Exploitation	Human operators socially engineered to approve rogue actions	ESCALATE path with structured reasoning trace
ASI10	Rogue Agents	Agent persists after kill switch via cached credentials	Sub-5 ms Redis invalidation; credential revocation cascade

TABLE III
KEY IETF WIMSE INTERNET DRAFTS (JULY 2026).

Draft	Purpose	Status
wimse-workload-creds-01	WIT/WIC identity tokens	Std. Track
wimse-s2s-protocol-07	Inter-agent auth	Std. Track
wimse-wpt-01	Tool-call proof-of-possession	Std. Track
wimse-http-signature-01	MCP transport signing	Std. Track
klrc-aiagent-auth-00	Agent identity lifecycle	Individual

operate at Levels 1–2 (ad-hoc or manual review, no automated enforcement).

NHI Governance Crisis. A May 2026 CSA whitepaper documents that non-human identities outnumber human users **45:1** on average (up to 144:1 in cloud-native environments). Only 15% of organisations feel confident preventing NHI-based attacks; 16%+ do not track AI identity creation at all.

F. IETF WIMSE Agent Identity Standards

The IETF Workload Identity in Multi-System Environments (WIMSE) working group standardises authentication for software workloads across runtime environments, with direct applicability to AI agent identities. Table III lists the key active Internet Drafts as of July 2026. The Workload Identity Token (WIT) carries a SPIFFE URI and a bound public key; the Workload Proof Token (WPT) — a JWT signed by the workload’s private key — provides proof-of-possession analogous to OAuth DPoP.

G. Model Context Protocol (MCP) Authorisation

The MCP Authorization Specification (RC, Jul. 28, 2026) [10] mandates OAuth 2.1 with PKCE for all

MCP client-server authorisation, Protected Resource Metadata (RFC 9728), Resource Indicators (RFC 8707), and token audience validation. A critical distinction must be drawn: *MCP OAuth 2.1 answers authentication* — “agent A is authenticated as user U with scope S ”; *Warden answers authorisation* — “agent A ’s invocation of tool T with parameters $\mathbf{p}$ is permitted under live policy $\mathcal{P}_t$.” These are complementary, non-overlapping layers.

H. EU AI Act and Regulatory Requirements

The EU AI Act [11] establishes a tiered compliance regime. Article 50 transparency obligations entered force **August 2, 2026**; Chapter III high-risk obligations for Annex III systems follow December 2, 2027. The articles most directly addressed by a pre-action gate are: Art. 9 (continuous *per-action* risk management), Art. 12 (tamper-evident automatic logging, six-month retention), Art. 14 (human oversight with intervention capability), and Art. 73 (24/72-hour incident reporting). Draft guidelines (May 2026) introduce a *compound system doctrine*: multi-agent pipelines are assessed end-to-end as a single high-risk system, making per-agent logging insufficient and requiring a unified cross-agent system of record.

III. PROBLEM STATEMENT

A. Formalising Pre-Action Authorisation

Let an agent session $\mathcal{S}$ be defined by the tuple $(A, U, \mathcal{P}, t_0)$, where A is the agent identity, U is the delegating user, $\mathcal{P}$ is the active policy set at session initiation, and t_0 is the start time. At each decision point the agent emits a *tool-call request*:

$$R = (A, T, \mathbf{p}, C)$$

TABLE IV
STANDARDS GAP: WHAT EXISTS VERSUS WHAT IS MISSING.

Layer	What Exists	Gap
AuthN	OAuth 2.1, OIDC, SPIFFE, WIMSE WIT, MCP Auth	None — solved
Pre-Action AuthZ	OAP, PCL (research only)	No NL compiler; no currency check; no ledger; no MCP integration
Model Safety	LLM guardrails (text boundary)	Probabilistic; tool calls unaddressed
Post-Action	LangSmith, Datadog, SIEM	Retrospective; cannot prevent harm

where T is the target tool, $\mathbf{p}$ is the parameter vector, and C captures runtime context (timestamp, prior decisions, session state). The pre-action authorisation problem is to compute:

$$\text{Decision}(R) \in \{\text{ALLOW}, \text{BLOCK}, \text{ESCALATE}\}$$

satisfying four properties simultaneously:

Policy currency. The evaluation must use $\mathcal{P}_{t_R}$ — the policy active at request time t_R — not the stale $\mathcal{P}_{t_0}$.

Determinism. For identical $(R, \mathcal{P}_{t_R})$, the decision must be identical. Probabilistic or LLM-based evaluation is inadmissible for regulatory compliance.

Latency bound. The decision must be produced within a wall-clock budget that does not materially degrade agent throughput (target: P95 < 50 ms).

Auditability. Each decision must be recorded in a tamper-evident log proving, post hoc, which policy version governed which action at which time.

The key insight from PCL [3] is that *semantic legitimacy* $\neq$ *execution legitimacy*: an action may be role-compatible yet violate authorisation provenance for the specific execution instance. A model that understands refunds is not thereby authorised to issue one at time t under the specific session and policy context.

B. The Standards Gap

Table IV maps the four properties against the current ecosystem. The pre-action authorisation layer is unambiguously empty.

C. Why Existing Approaches Do Not Suffice

IAM Platforms (Okta, Arcade.dev). These govern *connections* and *sessions*, not individual tool-call parameters. They cannot enforce that a specific invocation of `create_payment(amount=5000)` is prohibited under a policy capping transactions at \$200 for this agent’s session role.

Output Guardrails (Guardrails AI, NeMo Guardrails). These operate at the text-output boundary, checking the agent’s *response* for toxicity or PII. By the time output is generated, the API call has already executed. They add >500 ms via

LLM-based validation and have no concept of tool-call parameters.

Observability Tools (LangSmith, Langfuse, Datadog).

These record what happened after the fact. In regulated industries — banking, healthcare, pharma — *prevention*, not detection, is the compliance requirement. Art. 9 of the EU AI Act mandates continuous *per-action* risk management, not post-hoc review.

OAP and PCL. Both are research prototypes. OAP [2] lacks NL policy compilation and policy-currency invalidation. PCL [3] achieves 7 μ s latency but has no NL interface, no audit ledger, and no MCP integration. Neither has been validated in a production enterprise deployment.

IV. WARDEN: SYSTEM PROPOSAL

This section will be expanded once the system architecture is finalised. The four functional modules below constitute the design skeleton and represent the paper’s primary system contribution.

Warden intercepts agent tool calls over HTTP, gRPC, or MCP, evaluates each call against compiled policy rules, and records every decision in a tamper-evident audit ledger. Four functional modules constitute the system.

FR-1 — Policy Compiler. Ingests natural-language standard operating procedures (.md, .pdf) and compiles them to a deterministic JSON Abstract Syntax Tree (AST) with conflict and ambiguity detection. This is Warden’s ML contribution: an NLP pipeline that closes the gap between human-authored governance documents and machine-enforceable rules.

FR-2 — Runtime Gate. Returns ALLOW / BLOCK / ESCALATE via a two-path engine: a deterministic *fast path* (<20 ms) evaluates compiled AST rules against tool-call parameters; a *contextual slow path* (<150 ms) handles semantic ambiguity. Combined P95 target: <40 ms overhead.

FR-3 — Policy-Currency Check. Maintains a Redis in-memory cache with sub-5 ms broadcast invalidation on policy updates, ensuring revoked policy versions cannot govern future tool calls — a property none of the related systems provide.

FR-4 — Merkle Audit Ledger. Records every authorisation decision as a SHA-256 hash-chained block:

$$H_i = \text{SHA-256}(H_{i-1} \parallel \text{Seq}_i \parallel \text{ts}_i \parallel A_i \parallel T_i \parallel D_i \parallel \pi_i) \quad (2)$$

satisfying the verification invariant $\forall k \in [1, N] : \text{Hash}(B_k) = B_k.H \wedge B_k.H_{\text{prev}} = B_{k-1}.H$, enabling cryptographic proof that the complete decision history is unmodified — directly satisfying EU AI Act Art. 12.

V. CONCLUSION

This section will be completed after experimental evaluation.

Autonomous AI agents are being deployed in consequential enterprise settings at a pace that has outrun the governance infrastructure required to operate them safely. This paper has surveyed the academic and standards landscape, formalised the pre-action authorisation problem, and demonstrated that no existing system fills the gap between agent authentication (solved) and agent authorisation (unsolved). We proposed

Warden as a targeted solution occupying the critical but empty Layer 2 of the agent safety stack.

Open problems for future work: (i) empirical evaluation of the policy compiler’s precision and recall on real-world enterprise SOPs; (ii) formal verification of the Merkle ledger integrity invariant under adversarial block substitution; (iii) development of a community benchmark for pre-action authorisation effectiveness — a metric class entirely absent from current agent evaluation surveys [12].

ACKNOWLEDGEMENTS

The authors thank Dr. Nachiket Tapas for mentorship and guidance throughout this research.

REFERENCES

- [1] F. Xu et al., “TheAgentCompany: Benchmarking LLM Agents on Consequential Real World Tasks,” *NeurIPS 2025 Datasets & Benchmarks Track*, arXiv:2412.14161, 2024. [Online]. Available: <https://arxiv.org/abs/2412.14161>
- [2] Open Agent Passport Research Group, “Before the Tool Call: Deterministic Pre-Action Authorization for AI Agents,” arXiv:2603.20953, 2026. [Online]. Available: <https://arxiv.org/abs/2603.20953>
- [3] ILION Research Group, “Policy Constraint Layer (PCL): Deterministic Context-Bound Authorization,” Zenodo, v38, Mar. 2026. [Online]. Available: <https://zenodo.org/records/19222977>
- [4] OWASP Agentic Security Initiative, “OWASP Top 10 for Agentic Applications 2026,” Released Dec. 9, 2025. [Online]. Available: <https://genai.owasp.org>
- [5] National Institute of Standards and Technology, “Artificial Intelligence Risk Management Framework (AI RMF 1.0),” NIST AI 100-1, Jan. 2023. [Online]. Available: <https://doi.org/10.6028/NIST.AI.100-1>
- [6] National Institute of Standards and Technology, “AI Agent Standards Initiative,” NIST Center for AI Standards and Innovation (CAISI), Feb. 2026. [Online]. Available: <https://www.nist.gov/itl/ai-risk-management-framework>
- [7] Cloud Security Alliance, “Agent Identity Governance Framework (AIGF) v1,” CSA Labs, Mar. 2026. [Online]. Available: <https://labs.cloudsecurityalliance.org/agentic/agentic-identity-governance-framework-v1/>
- [8] Cloud Security Alliance, “Agentic NIST AI RMF Profile v1,” CSA Labs, Feb. 2026. [Online]. Available: <https://labs.cloudsecurityalliance.org/agentic/agentic-nist-ai-rmf-profile-v1/>
- [9] IETF WIMSE Working Group, “Workload Identity Credentials,” draft-ietf-wimse-workload-creds-02, Jul. 2026. [Online]. Available: <https://datatracker.ietf.org/doc/draft-ietf-wimse-workload-creds/>
- [10] Anthropic et al., “Model Context Protocol Authorization Specification,” Release Candidate, Jul. 28, 2026. [Online]. Available: <https://modelcontextprotocol.io/specification/2026-07-28/basic/authorization>
- [11] European Parliament and Council, “Regulation (EU) 2024/1689 — Artificial Intelligence Act,” *Official Journal of the European Union*, 2024. [Online]. Available: <https://artificialintelligenceact.eu/>
- [12] Agent Evaluation Survey Group, “Evaluation and Benchmarking of LLM-based Autonomous Agents: A Survey,” arXiv:2507.21504, 2025. [Online]. Available: <https://arxiv.org/abs/2507.21504>
- [13] IBM Institute for Business Value, “AI Agent Governance and Deployment Trends,” IBM Executive Study, Jun. 2026.
- [14] S. Zhou et al., “WebArena: A Realistic Web Environment for Building Autonomous Agents,” *ICLR 2024*, arXiv:2307.13854, 2024.
- [15] C. Jimenez et al., “SWE-bench: Can Language Models Resolve Real-world GitHub Issues?,” *ICLR 2024*, arXiv:2310.06770, 2024.
- [16] S. Yao et al., “ τ -bench: A Benchmark for Tool-Agent-User Interaction,” arXiv:2406.12045, 2024.